

CWE AI Working Group: New Entry Development

June 12, 2026

11:00am – 12:00pm EST

Attendance

Monika Akbar

Bob Heinemann

Steve Christey Coley

Caroline Rocha

Erick Galinkin

Sasha Romanosky

Agenda

- Status Updates
- CWE Release Information
- Work Planning

Meeting Notes

Status Updates

Steve delivered opening remarks on recent updates for the group, noting that no new subgroup members were present at the meeting. He introduced Bob Heinemann as a colleague who works primarily on hardware-related CWE content and has become more active in AI work.

Current AI-Related Work

Steve shared an update on current AI-related work, noting that the working group has recently focused on Sasha Romanosky's inclusion criteria paper and on additional submission analysis. Steve aims to complete the AI-related observed examples work by reviewing the latest narrower report focused on AI-specific tooling rather than general software weaknesses that happen to involve AI components.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

Submission Pipeline and Repository Support

In an update on the content development repository, Steve shared that the repository includes nine submissions that are specific to AI. Seven of those submissions propose new entries, but Steve noted that he expects most of them to become modifications based on feedback from recent discussions. Steve also plans to update the repository so submissions can be labeled as AI-related, making them easier to identify and search.

Prompt Injection Entry Updates

Steve suggested revisiting the prompt injection entry, CWE-1427, to which Kurt Seifried has made extensive proposed changes over the past couple of months. Responses from the AI WG were mixed, and no major changes had moved forward. Steve shared that he plans to work with Kurt to make the proposal available for more focused discussion, potentially by converting it into a submission.

CWE Release Information

CWE 5.0 Planning

In an update on the CWE release, Steve shared that the main release currently in focus is CWE 5.0, targeted for October 2026. A minor release such as CWE 4.21 might occur before then, but that possibility is not currently on the table. He added that the meaning and scope of CWE 5.0 have not yet been fully finalized. Steve also expects AI coverage to be one part of the CWE 5.0 announcement and wants more AI-related entries included in that release.

Schema and Life Cycle Changes

Steve shared that one major schema change planned for CWE 5.0 is support for different development models and life cycle phases across technologies. CWE's current life cycle model does not include AI-specific phases such as model development or training, and that similar issues have also arisen for hardware. Implementation details are still to be determined, but support for more technology-specific phases is planned. Steve added that defining AI-specific life cycle phases will be a task over the next couple of months.

Work Planning

Model Outputs and Security Relevance

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

The group dedicated part of the discussion to continuing its review of Sasha's write-up on inclusion criteria for AI-related weaknesses. The group had covered the paper in at least the previous two meetings and that only two discussion topics remained. Steve has also completed his own analysis but has not yet sent his direct feedback to the group.

Sasha asked whether weaknesses that affect a model's output, without modifying training data, model weights, or other internal system state, should qualify for CVE or CWE consideration. Sasha cited prompt injection and extraction-style attacks as examples and framed the question around whether manipulating prompts to obtain different or incorrect outputs should matter for inclusion criteria.

Steve shared that the answer depends on how the output is used, noting that if output guides security decisions or changes downstream system behavior, then the issue should be addressed somehow within CWE. CWE work is also moving toward broader coverage of incorrect behavior or incorrect outputs caused by certain inputs, including outside AI contexts.

Sasha said this differs from ordinary input-parsing flaws and noted that CVSS discussions had taken the position that output manipulation alone is not something they want to assess. Steve shared that prompt injection is already characterizable within CWE and emphasized that, for CWE purposes, intent does not matter. He said the key issue is the incorrect behavior that results, not whether a developer or attacker intended it.

Sasha also raised package hallucinations as an example, with Steve adding that package hallucinations are a weakness because the system generates incorrect output that others may be able to exploit, for example by creating malicious packages that match hallucinated names. He added that output matters when it guides or changes system behavior in security-relevant ways.

Monika pointed out the difficulty of assessing confidentiality, integrity, and availability for LLM-generated responses because such systems are non-deterministic and do not align neatly with more database-centered notions of CIA. She said Steve's concept of a range or tolerance for acceptable variation helped frame when incorrectness might exceed what should be acceptable. Caroline agreed with the points already raised about intent and context. Bob asked whether the group was assessing weaknesses in the model itself or in the integration of the model into other applications, and observed that output clearly matters in the latter case.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

Erick noted that much of the security impact stems from how systems around a model handle LLM outputs. He contrasted a basic chatbot that merely returns fabricated package names in a browser with a coding agent that writes or executes code based on those outputs. He said contextualizing the use case is important and that many disagreements come from shifting between a model in isolation and a model embedded in a broader software system.

Steve pointed out that this sounded more like a vulnerability assessment question than a weakness-definition question. Many CWEs, such as buffer overflows, only become vulnerabilities in particular contexts, but are still documented as weaknesses because they can lead to vulnerabilities under the right conditions. Steve said output correctness and acceptable variation may be similar in that respect, and closed the topic by noting that the group had not reached full agreement and that he expects to revisit it while doing more work on how CWE should represent correctness of outputs.

Evasion Attacks and CWE versus CVE

Sasha introduced the next discussion point, vulnerabilities leading to evasion attacks in generative AI and asked whether existing, CNA rule 4.17 effectively supersedes that discussion for CVE purposes if such cases are treated as detection bypass attacks. Steve said that if an evasion works, it should be characterizable somehow by a CWE. He compared this to older intrusion detection evasion work in which inconsistent packet interpretation allowed attacks to bypass detection. He noted that even if a product policy or CVE rule means a specific case does not receive a CVE, there is still often an underlying weakness that should be representable in CWE.

Erick pointed out that CNA rule 4.17 affects CVE assignment decisions, not whether something can be described as a weakness. Sasha raised questions about that separation and asked what the point of documenting a CWE would be if something is not CVE-assignable. Bob responded that CVEs are typically attack-oriented instantiations of weaknesses and that the underlying weakness can still be valuable to document even if some instances fall outside CVE scope.

Steve said he did not see that separation as a problem, adding that CVE may decide not to cover something, while developers may still need documentation of the underlying weakness or concern. Sasha said the explanation was helpful.

Publication Options and Broader Guidance

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

Steve asked what the output of Sasha's work should be for a broader public audience, noting that he could circulate the paper to the full group on the following Monday and asked whether the result should be a position paper, a blog post, material on the CWE website, or an ongoing discussion resource.

- Erick said a position paper or joint CWE and CVE blog post would be useful, especially in cases where the group is comfortable calling something a weakness but would still hesitate to assign a CVE. He pointed to package hallucination and prompt injection leading only to content-safety outcomes as examples of issues that may present real weaknesses or risks without clearly fitting CVE assignment practice. He also said the CVE working group had developed fairly solid perspectives, that no one seemed eager to change the CNA rules, and that some risks remain outside the scope of CVE assignment even when they matter operationally.
- Sasha said the long-term goal was a published, authoritative list of criteria on MITRE so researchers, CNAs, and others would know the rules for what is and is not CVE- or CWE-appropriate. Sasha noted that existing rules and blog posts address some issues, but that other areas remain silent, adding that future submitters to be able to consult documented criteria rather than revisit the same questions each time.

Steve said he would follow up offline with Sasha, Erick, and Alex Summers about publication options and timing.

Next Steps

Steve said the next meeting was expected in two weeks, although he noted that he might need to reschedule it and would follow up separately if needed. In the meantime, he plans to circulate Sasha's paper and continue work on release planning, submission handling, and guidance development for AI-related weaknesses.

Decisions Made

No final decisions made.

Action Items

- **Inclusion Criteria Paper Circulation:** Circulate Sasha's inclusion criteria paper to the full working group for broader review. (Steve)
- **Observed Examples Report Review:** Review the latest narrower observed examples report focused on AI-specific tooling. (Steve)

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

- **Proposed Prompt Injection Updates:** Work with Kurt Seifried to make the proposed prompt injection updates available for more focused discussion, potentially by converting the proposal into a submission. (Steve)
- **Labeling AI-Related Submissions in CDR:** Update the content development repository so AI-related submissions can be labeled and more easily identified. (Steve)
- **AI Updates Reflected in CWE 5.0:** Define candidate AI-specific life cycle phases for CWE 5.0 over the next couple of months. (TBD)
- **Inclusion Criteria Paper Publication:** Follow up offline with Sasha, Erick, and Alex Summers on publication options, scope, and timing for broader guidance or a position paper. (Steve)

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.